

Highlights

A Privacy-Aware Retrieval-Augmented Generation Framework for Cyber Threat Intelligence with MITRE ATT&CK Grounding and Guardrails

Maria Mahmood

- An integrated CTI RAG pipeline with STIX-based ATT&CK ingestion, privacy redaction, and injection filtering on CPU.
- Deterministic verification of cited ATT&CK technique identifiers against retrieved evidence.
- Pilot grounding performance of accuracy 0.9583, recall 1.0, and FNR 0.0 on 24 citations, expanded $n = 100$ accuracy 0.98 and F1 0.9853.
- Empirical comparison of input guardrails and redaction methods under CTI pilot, expanded CTI-100, and public prompt-injection workloads.

A Privacy-Aware Retrieval-Augmented Generation Framework for Cyber Threat Intelligence with MITRE ATT&CK Grounding and Guardrails

Maria Mahmood

Optical Networks and Technologies Laboratory (ONT Lab), National University of Sciences and Technology (NUST), Islamabad, Pakistan

Abstract

Large language models are increasingly used to query cyber threat intelligence (CTI) knowledge bases such as MITRE ATT&CK. When coupled with retrieval-augmented generation (RAG), they can surface relevant techniques quickly, yet standard pipelines expose unfiltered retrieved text to the model. This exposure enables prompt injection, leakage of sensitive indicators, and fluent but ungrounded technique citations. This paper presents a privacy-aware RAG architecture for ATT&CK-centric question answering designed for CPU-only deployment. The system ingests enterprise ATT&CK data from STIX, retrieves technique passages via a vector index, redacts sensitive spans before generation, screens queries for prompt injection, and applies a deterministic post-generation grounding check to every cited technique identifier. Each extracted identifier is validated against a local ATT&CK snapshot for existence and revocation status and is assessed for topical relevance to the retrieved evidence. On a hand-labelled pilot of 24 citations, the grounding module attains accuracy 0.9583, precision 0.9375, recall 1.0, F1-score 0.9677, false-positive rate 0.1111, and false-negative rate 0.0. On an expanded 100-citation grounding set (threshold fixed at 0.40), binary detection reaches accuracy 0.98, precision/recall/F1 0.9853, FPR 0.0312, and FNR 0.0147 (TP= 67, FP= 1, FN= 1, TN= 31). Manual retrieval evaluation yields Precision@3 = 0.783, substantially above combined automatic matching (0.3667), highlighting the gap between string-level and analyst-perceived

Email address: mmahmood.msai25seecs@seecs.edu.pk (Maria Mahmood)

relevance. Comparative experiments show that a lightweight keyword input guardrail achieves F1 0.80 on a CTI pilot at sub-millisecond latency with zero false positives, while recall falls to 0.1333 on both a public injection benchmark and an expanded 100-query CTI set—with distinct confusion matrices. A hardened regular-expression redactor reaches F1 0.9091 on a 28-example pilot at mean latency 0.23ms versus 56.18ms for named-entity redaction. The results indicate that layered, deterministic controls can improve the privacy and citation reliability of CTI RAG without specialised accelerators.

Keywords: Cyber threat intelligence, Retrieval-augmented generation, MITRE ATT&CK, Prompt injection, Privacy-preserving NLP, Citation grounding, Security guardrails

1. Introduction

Security operations centres and CTI teams continually map observed adversary behaviour to shared taxonomies, prioritise mitigations, and exchange indicators while limiting unnecessary disclosure of internal infrastructure. The MITRE ATT&CK knowledge base has become a widely adopted vocabulary for tactics, techniques, and procedures [1, 2]. At the same time, large language models combined with retrieval-augmented generation (RAG) [3] offer a convenient interface for querying large document collections in natural language. Applying RAG to ATT&CK and related CTI corpora is therefore attractive for analyst productivity.

The same design, however, introduces risks that are only partially addressed by generic chatbot defences. Retrieved passages may contain Internet addresses, file hashes, domains, or other sensitive indicators that should not be echoed in answers. Adversarial prompts may attempt to override system instructions and exfiltrate context. Independently of privacy failures, models may emit technique identifiers that are fabricated, revoked, or unsupported by the evidence actually retrieved. In an operational setting, such citations are particularly harmful because they appear authoritative and can misdirect investigation.

Production CTI platforms such as OpenCTI and MISP focus on structured STIX/TAXII sharing rather than LLM-mediated semantic question answering [4, 5]. Privacy-aware RAG research emphasises selective disclosure before generation [6], and a growing literature studies prompt injection and over-defence on security-related wording [7, 8, 9, 10]. Parallel work applies

RAG to ATT&CK-oriented tasks such as technique annotation and attack investigation [11, 12, 13, 14]. What remains less developed is an end-to-end ATT&CK RAG service that jointly enforces input filtering, dual-stage privacy redaction, and deterministic verification of cited technique identifiers under an explicit CPU-only constraint.

This paper presents such a system. Enterprise ATT&CK objects are ingested from STIX into a vector index. Online requests pass through authentication and rate limiting, prompt-injection screening, semantic retrieval, privacy redaction of retrieved chunks, LLM generation on redacted context only, post-generation grounding of technique identifiers, and a final output privacy scan. The grounding stage classifies each cited identifier as fabricated, revoked, real but irrelevant to the retrieved evidence, or real and plausible.

The contributions are threefold. First, we describe a deployable CTI RAG architecture that integrates STIX-based ATT&CK ingestion, vector retrieval, dual-stage indicator redaction, and input guardrails without requiring a GPU. Second, we introduce a domain-specific ATT&CK output grounding procedure that verifies cited technique identifiers against a local authoritative snapshot and the retrieved context. Third, we report an evaluation that combines retrieval Precision@ k , redaction accuracy and latency, input-guardrail comparison on CTI pilot and public injection data, expanded $n \approx 100$ resources for grounding and CTI injection queries, and pilot-scale adversarial leakage probes, using metrics taken from frozen experimental artefacts.

The remainder of the paper is organised as follows. Section 2 reviews related work. Section 3 details the architecture and algorithms. Section 4 presents experimental results. Section 5 discusses limitations and future work. Section 6 concludes.

2. Related Work

2.1. Prior work

Operational CTI platforms such as OpenCTI and MISP provide mature workflows for storing, correlating, and sharing structured threat intelligence using STIX and TAXII [4, 5]. MITRE ATT&CK and the associated STIX distributions supply a curated taxonomy of adversary behaviour and machine-readable technique objects [1, 15, 2]. These resources are foundational for structured CTI management, yet they do not by themselves offer

natural-language question answering with privacy filtering or verification of generated technique citations.

Standard RAG architectures retrieve top-ranked passages and condition generation on that context [3, 17, 18]. In their basic form they assume that retrieved text may be shown to the model and that generated identifiers are reliable. Secure RAG surveys and system analyses document retrieval poisoning, prompt injection, and leakage as first-class risks [19, 8, 9]. SD-RAG enforces selective disclosure after retrieval and before generation [6]. TrustShare addresses privacy and trust for CTI exchange without LLM retrieval [20]. Prompt-injection research further shows that detectors can over-flag benign security language [7, 10, 21].

A second line of work applies RAG specifically to CTI and ATT&CK. CyRAG and GraphCyRAG retrieve from structured cyber entities and knowledge graphs spanning CVE, CWE, CAPEC, and ATT&CK [13]. RAGIntel retrieves MITRE ATT&CK knowledge to support attack investigation queries [12]. TechniqueRAG targets technique annotation in CTI reports through retrieval, generation, and domain-oriented re-ranking [11]. CTI-Connect provides a benchmark for retrieval-augmented models over heterogeneous CTI sources, including ATT&CK [14]. These systems strengthen ATT&CK-oriented retrieval and generation, but their primary objectives differ from integrated runtime privacy and post-hoc identifier verification in a service pipeline.

2.2. Limitations for CTI RAG

Across these strands, several limitations remain salient for SOC-facing ATT&CK assistants. CTI platforms optimise structured sharing rather than grounded natural-language generation. Generic RAG deployments rarely redact CTI indicators before generation or re-scan answers for residual leakage. Privacy-aware RAG addresses selective disclosure but does not provide a deterministic MITRE technique-identifier verifier tied to retrieved evidence. CTI-RAG systems improve retrieval or annotation quality, yet typically omit a measured output stage that flags fabricated, revoked, or evidence-irrelevant technique identifiers together with interactive injection controls. Finally, general-purpose injection detectors may miss domain-specific attacks or over-block legitimate analyst queries, and heavier model-based guards can impose substantial latency.

2.3. Positioning of this work

The present system addresses the above gaps with an integrated, CPU-oriented pipeline that combines STIX-based ATT&CK ingestion, semantic retrieval, dual-stage privacy redaction, a lightweight input injection filter, and deterministic technique-identifier grounding. Relative to CTI platforms, it adds semantic RAG with privacy and citation controls. Relative to TechniqueRAG, RAGIntel, and related CTI-RAG systems, it does not target large-scale annotation leaderboards, instead it emphasises a service path in which every cited identifier is checked for existence, revocation, and relevance to the evidence actually retrieved. Relative to SD-RAG, it does not claim superior privacy scores on that work’s original benchmark, it claims a practical ATT&CK-centric integration with explicit pilot and expanded grounding metrics and measured guardrail and redaction trade-offs. Table 1 summarises this qualitative positioning.

Table 1: Qualitative comparison with representative related systems. “Partial” denotes a related capability that is not realised as an integrated post-generation ATT&CK identifier verification stage over free-text answers.

System or line of work	STIX/ATT&CK	Semantic RAG	Privacy redaction	Injection filter	ATT&CK ID grounding	CPU-first path
OpenCTI / MISP [4, 5]	Yes	No	Sharing controls	N/A	No	Yes
Standard RAG [3]	Possible	Yes	No by default	Optional	No	Depends
SD-RAG [6]	Not CTI-specific	Yes	Yes	Considered	No	Not primary claim
TechniqueRAG [11]	Yes	Yes	No	No	Partial	Possible
RAGIntel [12]	Yes	Yes	No	No	Retrieval-grounded answers	Possible
CyRAG / GraphCyRAG [13]	Yes	Yes	No	No	Graph-enhanced retrieval	Possible
TrustShare [20]	CTI sharing	No	Yes	N/A	No	Yes
This work	Yes	Yes	Yes	Yes	Yes	Yes

3. Proposed Method

3.1. System overview

Figure 1 presents the end-to-end architecture. A FastAPI service [23] accepts analyst queries under API-key authentication and rate limiting. After an input prompt-injection check, the system retrieves ATT&CK technique passages from a vector index, redacts sensitive indicator spans, and conditions LLM generation on the redacted context only. Cited technique identifiers are then verified against a local ATT&CK snapshot and the retrieved evidence. An output privacy scanner is applied before the final response is returned. Responses include the answer text, source labels, structured grounding verifications, ungrounded identifiers, a review flag, and stage timings.

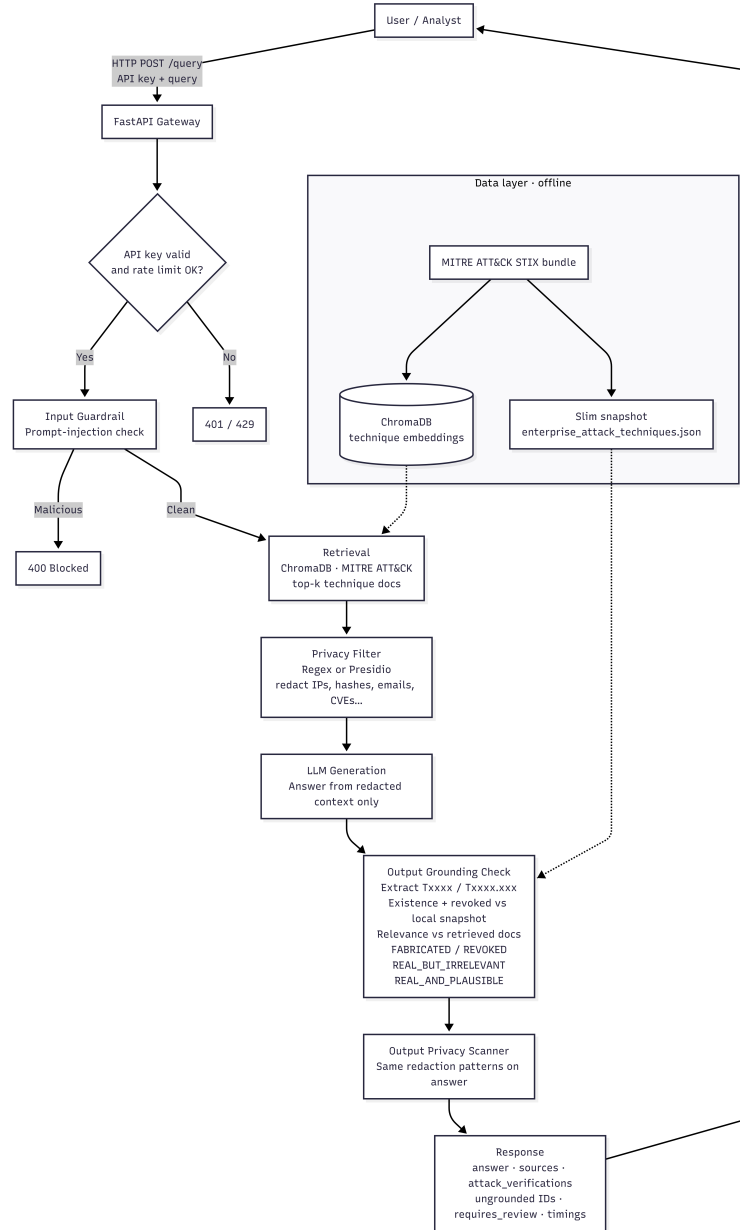


Figure 1: System architecture of the proposed privacy-aware CTI RAG pipeline. Queries are authenticated and screened for prompt injection. Relevant MITRE ATT&CK passages are retrieved and redacted before generation. Cited technique identifiers are verified against a local ATT&CK snapshot and the retrieved evidence; an output privacy scan is applied before the final response. The data layer provides the vector index and the technique snapshot used at runtime.

3.2. Ingestion and retrieval

Enterprise ATT&CK attack-pattern objects are obtained from the MITRE CTI STIX distribution [15, 16]. Objects are converted to textual fields and embedded in ChromaDB [24]. At query time the service retrieves the top- k technique documents. Interactive defaults use $k = 3$, evaluation also reports $k = 10$.

3.3. Privacy filtering

Spans corresponding to Internet addresses, domains, electronic mail addresses, cryptographic hashes, and CVE identifiers are redacted from retrieved chunks before generation. Two families are supported: named-entity recognition via Microsoft Presidio [25] and deterministic regular-expression transducers, including a hardened variant that recognises defanged indicator notation common in CTI text (bracketed dots, “(dot)” forms, and `hxxp`-style URLs). After generation, an output scanner applies the same detectors to the answer text to intercept residual leakage.

3.4. Input guardrail

User queries are screened for prompt-injection patterns by a keyword and heuristic baseline embedded in the request path. This baseline is the guardrail enabled by default in the deployed service. For comparison, LLM Guard’s prompt-injection classifier and a NeMo Guardrails jailbreak heuristic are evaluated on a CTI pilot set, an expanded CTI-100 query set, and the public `deepset/prompt-injections` benchmark [22]. Model-based detectors are retained for scientific comparison; they are not enabled by default because of higher latency and, for LLM Guard, additional false positives on legitimate CTI phrasing in the pilot set.

3.5. ATT&CK output grounding

Technique identifiers matching the regular expression pattern for ATT&CK techniques and sub-techniques are extracted from the generated answer. Each identifier is resolved against a slim local snapshot derived from ATT&CK, which stores the technique name, description, revocation flag, and canonical URL. Classifications are defined as follows. An identifier absent from the snapshot is labelled fabricated. An identifier present but marked revoked or deprecated is labelled revoked. Active identifiers are labelled real and plausible or real but irrelevant according to a deterministic topical-overlap score between the retrieved context and the official technique description, using a

threshold of 0.40 and a short-context-first argument order. If the snapshot is unavailable, the identifier is labelled unverified. The review flag is raised only when at least one cited identifier is not classified as real and plausible. When inline annotation is enabled, longer identifiers are substituted before shorter ones under boundary-safe matching so that parent techniques do not corrupt sub-technique strings. The grounding module is covered by automated unit tests for extraction (including sub-techniques), revoked and fabricated classification, and boundary-safe annotation.

4. Evaluation

4.1. Experimental setup

All experiments were conducted on a CPU-only workstation with eight physical and sixteen logical cores, 15.35 GB of memory, and no GPU. Interactive serving used FastAPI [23], generation used a hosted LLM endpoint. Unless stated otherwise, numerical results are taken from frozen project evaluation artefacts without additional fabrication or undisclosed rounding. F1-scores are computed from integer true-positive, false-positive, and false-negative counts; recomputing F1 from rounded precision and recall alone may differ in the fourth decimal place.

4.2. Evaluation resources used in this manuscript

The quantitative tables in this section are backed by the following labelled resources. Gold labels (where applicable) were assigned by fixed rules rather than by an LLM classifier. Case text for the expanded evaluation resources was drafted with assistance from Grok (xAI) under those rules; see the generative-AI declaration at the end of the paper for the full list of files. Construction notes are stored alongside each file under `experiments/data/`.

- **ATT&CK grounding pilot** (`grounding_labeled_set.json`): 20 cases / 24 citations used for the original pilot metrics.
- **ATT&CK grounding expanded set** (`grounding_eval_100.json`): 100 cases / 100 citations with class mix 32 real-and-plausible, 28 real-but-irrelevant, 28 fabricated, and 12 revoked. In this version of the set, all 12 revoked citations use the single revoked identifier T1086 (historical PowerShell technique entry). Overlap threshold 0.40 was fixed from earlier fixture trials and was *not* retuned on this set.

- **CTI prompt-injection pilot:** 6 positive / 10 negative queries used in the pilot guardrail table.
- **CTI prompt-injection expanded set** (`guardrail_cti_eval_100.json`): 45 injection / 55 benign CTI analyst queries. This set *includes* the original 16 pilot strings for continuity and is therefore an expanded evaluation resource rather than a fully disjoint held-out test set. Public `deepset/prompt-injections` metrics remain a separate table and are never blended with CTI scores.

Additional larger resources for regular-expression redaction (`regex_eval_100.json`) and adversarial pipeline probes (`adversarial_eval_100.json`) have been prepared in the repository for future measurement campaigns; they are not used for numeric claims in this manuscript. Redaction accuracy and adversarial leakage results below therefore report only the frozen 28-case and 6-case pilot artefacts, respectively.

4.3. Retrieval quality

Table 2 reports Precision@ k for ATT&CK technique retrieval. Automatic exact, semantic, and combined scores are conservative relative to human judgements: manual Precision@3 equals 0.783 and manual Precision@10 equals 0.74. Combined automatic Precision@3 and Precision@10 are 0.3667 and 0.26, respectively, indicating that string-level matching underestimates analyst-perceived relevance.

Table 2: Retrieval Precision@ k on MITRE ATT&CK technique search.

Metric	Exact	Semantic	Combo	Manual
Precision@3	0.30	0.30	0.3667	0.783
Precision@10	0.21	0.24	0.26	0.74

4.4. Privacy redaction

On a twenty-eight-example regular-expression accuracy suite, the hardened transducer achieves precision 0.8333, recall 1.0, and F1-score 0.9091. Micro-benchmarks that isolate redaction calls yield mean latency 56.1828 ms for Presidio, 0.2305 ms for the hardened regular-expression variant, and 0.1503 ms for a faster regular-expression baseline. Figures 2 and 3 summarise latency and throughput.

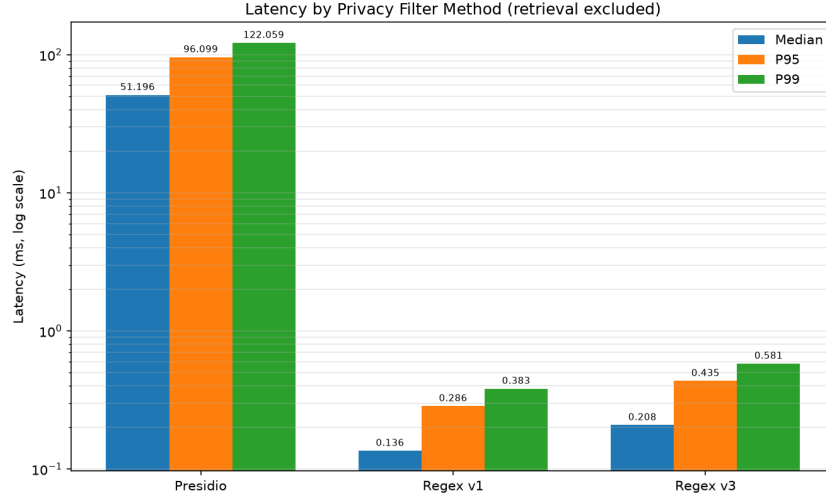


Figure 2: Redaction latency on the CPU-only micro-benchmark.

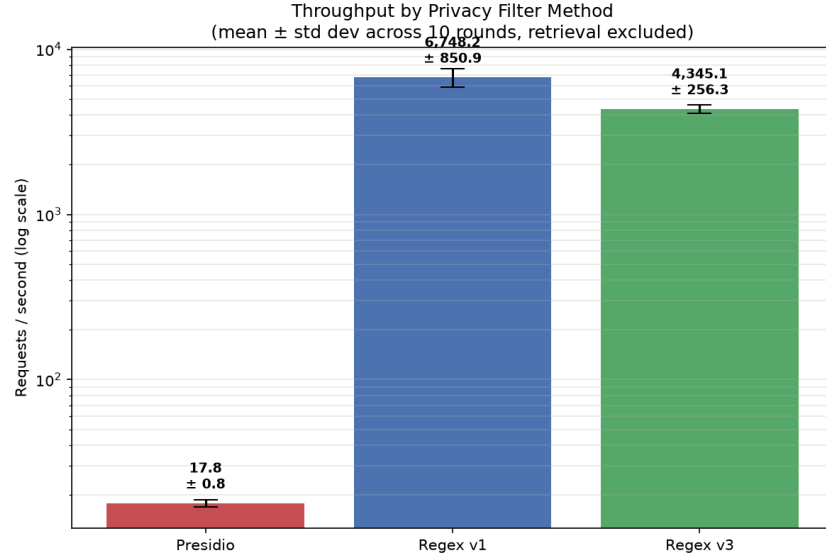


Figure 3: Redaction throughput on the CPU-only micro-benchmark.

4.5. Input guardrail comparison

We compare the repository keyword baseline, LLM Guard, and a NeMo Guardrails jailbreak heuristic on (i) a CTI pilot set (6 positive / 10 negative)

and (ii) 116 public benchmark examples from `deepset/prompt-injections`. Table 3 lists metrics from the stored pilot artefact. The keyword baseline attains F1 0.80 on the CTI pilot at 0.0118ms average latency with a false-positive rate of zero, while public-set recall falls to 0.1333 (average latency 0.0111 ms). LLM Guard improves public-set recall to 0.3167 at 225.3986ms average latency and records a CTI pilot false-positive rate of 0.10. The evaluated NeMo heuristic detects no injections on either set; CTI pilot average latency is 1470.4921ms with maximum latency 16315.1442ms. Figures 4 and 5 illustrate accuracy and latency on the pilot comparison.

Table 3: Prompt-injection guardrail comparison on the CTI pilot and public benchmark (stored evaluation results). Latencies are average milliseconds per query from the same artefact.

Method	Set	Precision	Recall	F1	FPR	Avg. latency (ms)
Keyword baseline	CTI pilot	1.0	0.6667	0.80	0.0	0.0118
Keyword baseline	Public	1.0	0.1333	0.2353	0.0	0.0111
LLM Guard	CTI pilot	0.75	0.50	0.60	0.10	279.8099
LLM Guard	Public	1.0	0.3167	0.481	0.0	225.3986
NeMo heuristic	CTI pilot	0.0	0.0	0.0	0.0	1470.4921
NeMo heuristic	Public	0.0	0.0	0.0	0.0	697.161

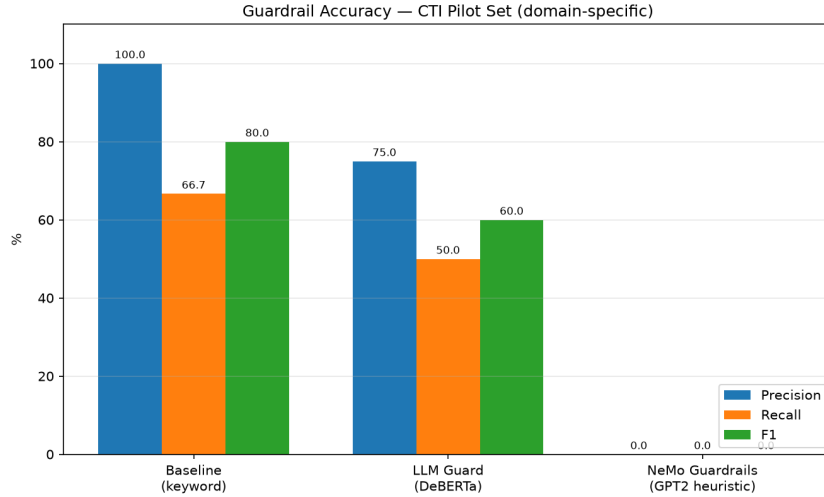


Figure 4: Guardrail accuracy on the CTI pilot set (legacy pilot artefact).

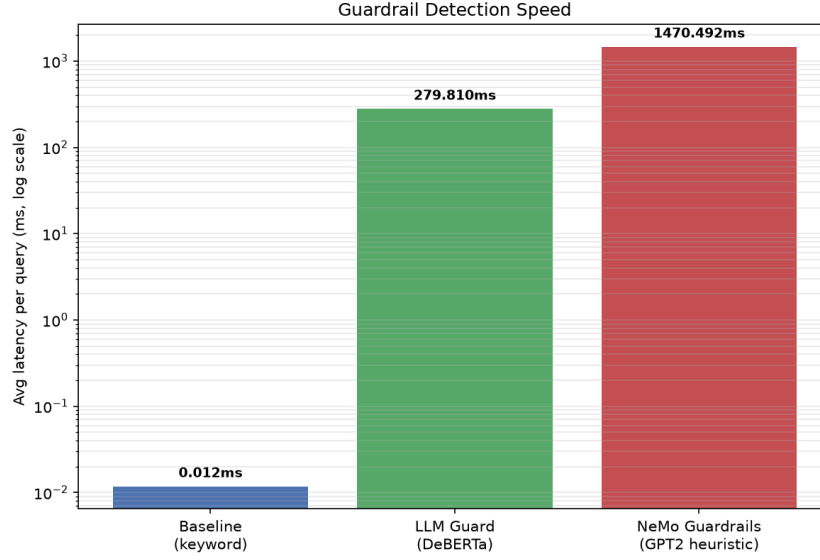


Figure 5: Guardrail latency across methods (legacy pilot artefact).

On the expanded CTI-100 set (`guardrail_cti_eval_100.json`; 45 injection / 55 benign), the keyword baseline records TP= 6, FP= 0, FN= 39, TN= 55, hence precision 1.0, recall 0.1333, F1 0.2353, and FPR 0.0. The matching precision/recall/F1 rates on the public set arise from a different confusion matrix (public keyword baseline: TP= 8, FP= 0, FN= 52, TN= 56) and should not be read as a duplicated table row. Because the expanded set reuses the original 16 pilot queries, the result is best interpreted as stress-testing the keyword baseline on a larger CTI vocabulary rather than as a fully disjoint held-out estimate; the low overall recall still indicates limited generalisation to broader injection paraphrases. A separate recall figure restricted to the 84 queries that are not in the pilot set is left for future work and is not reported here.

4.6. *ATT&CK* grounding pilot and expanded evaluation

A hand-labelled pilot (`grounding_labeled_set.json`; 20 cases / 24 citations) covers real and plausible, real but irrelevant, fabricated, and revoked identifiers. Binary detection treats fabricated, revoked, and real-but-irrelevant citations as positives. The module records fifteen true positives, one false positive, zero false negatives, and eight true negatives, corresponding to accuracy 0.9583, precision 0.9375, recall 1.0, F1-score 0.9677, false-

positive rate 0.1111, and false-negative rate 0.0. Exact four-class agreement is 0.9583. Extraction misses on gold-flagged identifiers are scored as false negatives rather than true positives.

On the expanded 100-citation set (`grounding_eval_100.json`) with the same threshold (0.40), binary detection yields TP= 67, FP= 1, FN= 1, TN= 31 (accuracy 0.98, precision 0.9853, recall 0.9853, F1 0.9853, FPR 0.0312, FNR 0.0147). Exact four-class match rate is 0.97, with perfect exact match on fabricated (28/28) and revoked (12/12) identifiers. Remaining errors concentrate on the lexical relevance boundary between real-and-plausible and real-but-irrelevant. The revoked class in this set uses only T1086; the perfect revoked match rate therefore demonstrates correct handling of that known revoked identifier and of the snapshot’s revocation flag, but does not by itself establish generality across the broader population of revoked ATT&CK techniques.

4.7. Scalability

In the recorded service benchmark, cached answers reached a peak throughput of 329.39 requests per second at one hundred concurrent users. A separate fresh-query load test with unique prompts and no cache reuse achieved 0.36 requests per second over ten requests, with a 30% failure rate. The dominant cause was the external LLM provider’s free-tier rate limit rather than local CPU saturation. A concurrency ramp isolating the hardened redaction filter (two to sixty-four worker threads) maintained recall of 1.0 at every level, with average CPU utilisation approximately 3–6% and peak resident memory on the order of 12 GB on the evaluation host.

4.8. Adversarial leakage probes

A six-case qualitative suite (indirect extraction, role-play, verbatim context replay, and related attempts) recorded three blocks by the injection filter and three protected generations with no residual indicator leakage in the stored artefact (`adversarial_results.json: potential_leaks= 0`).

5. Discussion

The experiments suggest that inexpensive deterministic controls can improve privacy and citation reliability in ATT&CK-centric RAG without GPU

resources. On the grounding pilot, the false-negative rate is zero for the defined positive class; on the expanded $n = 100$ set the false-negative rate remains low (0.0147). Regular-expression redaction yields large latency gains over named-entity recognition on CPU micro-benchmarks while retaining high recall on indicator-oriented tests. The keyword input guardrail offers strong pilot-set precision at negligible cost, but expanded CTI-100 and public-set recall near 0.13 show limited generalisation to paraphrased injections.

Several limitations should be stated explicitly. The grounding studies, though expanded to $n = 100$, remain constructed evaluation resources rather than multi-annotator production benchmarks drawn from live SOC traffic. In particular, the revoked class in `grounding_eval_100.json` is concentrated on a single technique identifier (T1086), so revoked-detection performance should not be over-generalised. The CTI-100 injection resource includes the original pilot queries and is therefore an expanded rather than fully disjoint evaluation set. Automatic retrieval scores remain below manual judgements. Model-based injection detectors improve some recall measures but introduce latency and domain false positives. The grounding module evaluates identifiers that appear in generated text; it cannot compensate when the generator omits the most relevant technique. Threshold selection for topical overlap was informed by fixture-style matching and mismatch trials and was not retuned on the 100-citation set.

Two implementation limits relevant to long-running deployment remain. The in-memory response cache is TTL-based but not size-bounded, and the per-key request counters used for rate limiting grow without a fixed upper bound. Both are acceptable for a prototype and short evaluation campaigns, but a production deployment should replace them with bounded stores.

Future work includes diversifying revoked identifiers in the grounding evaluation set, reporting injection metrics on the novel-only subset of CTI-100, completing measurement on `regex_eval_100.json` and `adversarial_eval_100.json`, exploring calibrated semantic relevance scores as a complement to lexical overlap, extending verification to additional structured claim types such as CVE identifiers, and studying adaptive combinations of keyword and model-based injection detectors under explicit over-defence budgets [7].

6. Conclusion

The paper presents a privacy-aware retrieval-augmented generation framework for MITRE ATT&CK-centric cyber threat intelligence question answering. The system integrates STIX-based ingestion, semantic retrieval, dual-stage indicator redaction, prompt-injection filtering, and deterministic verification of cited technique identifiers. Using frozen evaluation artefacts, the study supports CPU-first deployment: the grounding module achieves recall 1.0 and FNR 0.0 on a 24-citation pilot and accuracy 0.98 (F1 0.9853) on an expanded 100-citation set, while redaction and guardrail experiments quantify clear accuracy–latency trade-offs and show that keyword pilot recall does not generalise unchanged to broader CTI injection paraphrases. The architecture offers a practical template for SOC-oriented language tooling in which privacy constraints and citation checks remain enforceable and independent of generative nondeterminism.

Declaration of generative AI and AI-assisted technologies in the writing process

During the preparation of this work the author used Grok (xAI) to assist in drafting evaluation-set case text under fixed labelling rules for the expanded evaluation resources `grounding_eval_100.json`, `guardrail_cti_eval_100.json`, `regex_eval_100.json`, and `adversarial_eval_100.json`. Gold labels, where applicable, were assigned by fixed rules rather than by a generative model. After using this tool, the author reviewed and edited the content as needed and takes full responsibility for the content of the published article. Generative AI was not used to invent quantitative results, analyse experimental artefacts, or draw the scientific conclusions reported in this paper.

References

- [1] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington and C. B. Thomas, *MITRE ATT&CK: Design and philosophy*, MITRE Technical Report, 2018.
- [2] MITRE Corporation, *MITRE ATT&CK*, <https://attack.mitre.org>, accessed 2026.
- [3] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. Yih, T. Rocktäschel, S. Riedel and D. Kiela, *Retrieval-augmented generation for knowledge-intensive NLP tasks*, in: Advances in Neural Information Processing Systems, 2020.
- [4] Filigran, *OpenCTI: Open Cyber Threat Intelligence Platform*, <https://github.com/OpenCTI-Platform/opencti>, accessed 2026.
- [5] CIRCL, *MISP: Malware Information Sharing Platform*, <https://github.com/MISP/MISP>, accessed 2026.
- [6] A. Al Masoud, M. Arazzi and A. Nocera, *SD-RAG: A prompt-injection-resilient framework for selective disclosure in retrieval-augmented generation*, arXiv:2601.11199, 2026.
- [7] H. Li, X. Liu, N. Zhang and C. Xiao, *PIGuard: Prompt injection guardrail via mitigating overdefense for free*, in: Proceedings of the Annual Meeting of the Association for Computational Linguistics, 2025.
- [8] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz and M. Fritz, *Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection*, in: Proceedings of the ACM Workshop on Artificial Intelligence and Security, 2023.
- [9] Y. Liu, G. Deng, Z. Xu, Y. Li, Y. Zheng, Y. Zhang, L. Zhao, T. Zhang, K. Wang and Y. Liu, *Prompt injection attack against LLM-integrated applications*, arXiv:2306.05499, 2023.
- [10] F. Perez and I. Ribeiro, *Ignore previous prompt: Attack techniques for language models*, arXiv:2211.09527, 2022.

- [11] *TechniqueRAG: Retrieval augmented generation for adversarial technique annotation in cyber threat intelligence reports*, arXiv:2505.11988, 2025.
- [12] A. Alhuzali, *LLM-powered threat intelligence: a retrieval-augmented generation approach for cyber attack investigation*, PeerJ Computer Science 11 (2025) e3371.
- [13] Pacific Northwest National Laboratory, *Retrieval augmented generation for robust cyber defense*, PNNL Report, 2024.
- [14] *CTIConnect: A benchmark for retrieval-augmented LLMs over heterogeneous cyber threat intelligence*, arXiv:2510.11974, 2025.
- [15] MITRE Corporation, *MITRE Cyber Threat Intelligence Repository*, <https://github.com/mitre/cti>, accessed 2026.
- [16] OASIS Open, *STIX Version 2.1*, OASIS Standard, 2021.
- [17] OpenAI, *Question answering using embeddings-based search*, OpenAI Cookbook, <https://github.com/openai/openai-cookbook>, accessed 2026.
- [18] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, M. Wang and H. Wang, *Retrieval-augmented generation for large language models: A survey*, arXiv:2312.10997, 2024.
- [19] *Securing retrieval-augmented generation: A risk assessment framework*, arXiv:2505.08728, 2025.
- [20] D. P. Trivellato et al., *TrustShare: A framework for secure and privacy-preserving cyber threat intelligence sharing*, Future Internet 17 (7) (2025) 289.
- [21] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter and M. Fredrikson, *Universal and transferable adversarial attacks on aligned language models*, arXiv:2307.15043, 2023.
- [22] deepset, *prompt-injections dataset*, <https://huggingface.co/datasets/deepset/prompt-injections>, accessed 2026.
- [23] S. Ramírez, *FastAPI*, <https://fastapi.tiangolo.com>, accessed 2026.

- [24] Chroma, *Chroma: the AI-native open-source embedding database*, <https://github.com/chroma-core/chroma>, accessed 2026.
- [25] Microsoft, *Presidio: Data protection and de-identification SDK*, <https://github.com/microsoft/presidio>, accessed 2026.